



CYBERSECURITY POLICY

ENDAVA PLC | JUNE 2025

CONTENTS

1 INTRODUCTION.....6

2 POLICY PURPOSE6

3 POLICY SCOPE6

4 POLICIES.....6

4.1 GUIDING PRINCIPLES6

4.2 SECURITY RESPONSIBILITIES AT ENDAVA8

4.2.1 Responsibilities of all personnel8

4.2.2 CyberSecurity Group8

4.2.3 Security Risk Management Process9

4.2.4 Controls and Policy Committee10

4.3 SECURITY TRAINING AND AWARENESS10

4.4 GENERAL COMPUTER AND NETWORK USAGE11

4.5 END USER COMPUTING12

4.5.1 Asset Management12

4.5.2 Operating Systems12

4.5.3 Malware protection13

4.5.4 Credentials13

4.5.5 Installing hardware and software14

4.5.6 Required security features15

4.5.7 Wireless networks15

4.5.8 Data storage and backup16

4.5.9 Use of cloud based services16

4.5.10 Remote working16

4.5.11 Administrator access17

4.5.12 Prohibited content.....17

4.5.13 Monitoring and privacy18

4.5.14 Use of end user computing resources18

4.5.15 Return, reuse and disposal of equipment18

4.5.16 Use of non Endava equipment for Endava business18

4.6 SERVERS & INFRASTRUCTURE.....19

4.6.1	Control of infrastructure	20
4.6.2	Asset management	20
4.6.3	Network connections and firewalls	20
4.6.4	Wireless networks	20
4.6.5	Operating system configuration and updates	21
4.6.6	Accounts and passwords	21
4.6.7	Software installations and upgrades	21
4.6.8	Management, monitoring & logging	22
4.6.9	Operational resiliency	22
4.7	EMAIL AND ELECTRONIC COMMUNICATIONS	23
4.7.1	Appropriate use	23
4.7.2	Confidentiality	24
4.7.3	Mobile access	24
4.7.4	Privacy & monitoring	25
4.8	INFORMATION CLASSIFICATION, ACCESS, & HANDLING	25
4.8.1	Owner & custodian	25
4.8.2	Classification levels	25
4.8.3	Employee access to information	26
4.8.4	Privileged access	26
4.8.5	External access	27
4.8.6	Client requirements	27
4.8.7	Access controls	27
4.9	ENCRYPTION	28
4.10	SECURE SOFTWARE DEVELOPMENT	29
4.10.1	Security and privacy by design	29
4.10.2	Development practices	29
4.10.3	Use of external software	29
4.10.4	Separation of environments	30
4.10.5	Testing and test data	30
4.11	SECURITY TESTING & ASSESSMENT	30
4.11.1	Responsibility for testing and assessment	30
4.11.2	Technical testing and assessment	31
4.11.3	Testing of non Endava systems	31
4.11.4	Personnel security testing	31

4.11.5 Compliance testing and assessment	31
4.11.6 Performance testing	32
4.11.7 Test reporting.....	32
4.12 SOFTWARE VULNERABILITY MANAGEMENT	32
4.12.1 Responsibility	32
4.12.2 Vulnerability scanning	33
4.12.3 Classification of vulnerabilities.....	33
4.12.4 Vulnerability remediation plans	34
4.12.5 Vulnerability remediation activities	35
4.12.6 Verification of remediation.....	35
4.13 END OF LIFE (UNSUPPORTED) SOFTWARE.....	35
4.13.1 Avoidance of End of Life software.....	36
4.13.2 Detection & classification of End of Life software	36
4.13.3 Remediation of End of Life software	36
4.14 WORKING ON CLIENT SITES & SYSTEMS	37
4.15 THIRD PARTY VENDOR MANAGEMENT & ACCESS	37
4.15.1 Applicable third parties	37
4.15.2 Contracts and agreements.....	37
4.15.3 INFORMATION SECURITY ASSESSMENTS.....	38
4.15.4 Periodic reassessments	39
4.16 PROTECTION OF PERSONAL DATA	39
4.16.1 Collecting personal data.....	40
4.16.2 Definition of personal data.....	40
4.16.3 Storage and transmission of personal data.....	40
4.16.4 Access to personal data	40
4.16.5 Retention and destruction of personal data	41
4.16.6 Individual rights	41
4.16.7 Third parties.....	41
4.17 CYBERSECURITY INCIDENT RESPONSE	42
4.17.1 Incident Response Planning	42
4.17.2 Incident Response Plan Updates	42
4.17.3 Incident Response Plan Testing	42
4.17.4 External Incident Response Assistance	42
4.17.5 Incident Reporting Guidelines	43

4.18 PHYSICAL SECURITY 44

4.18.1 Endava premises 44

4.18.2 Access devices..... 44

4.18.3 Securing information 45

4.18.4 Clean desk and clean screen policy..... 45

4.18.5 Securing IT assets..... 45

4.18.6 Disposal of information 46

4.18.7 Visitors 46

4.18.8 Filming, recording and photography..... 46

4.18.9 Offsite storage of documents and media 47

4.18.10 Reporting physical security incidents 47

4.19 TRAVEL SECURITY 47

4.20 OMISSIONS & EXCEPTIONS 47

5 GOVERNANCE & OVERSIGHT 48

6 BREACH OF POLICY 48

7 AMENDMENTS 48

8 POLICY REVISION..... 49

1 INTRODUCTION

Endava plc (hereafter, 'Endava' or the 'Company') has a clear and unchanging purpose to create an environment and culture that breeds success, enabling our people to be the best they can be. It is underpinned by our values which guide the way we behave. Our Group policies form part of Endava's Code of Conduct which focuses our attention on working respectfully with each other; on helping our clients to succeed by recognizing them as individuals; and on mitigating risk by delivering responsibly to the market and to our investors.

This policy supports Endava's purpose and values by enabling the maintenance of its position as a **trusted** partner to our employees and our customers by providing guidance on the protection of all types of information used or handled at Endava. It is a key component Endava Information Security Management System, which has been developed to support all efforts to keep Endava secure. This policy is also written to allow the company to be **adaptable, thoughtful, open, and smart**, supporting innovation and experimentation to find solutions to our customers' needs.

2 POLICY PURPOSE

Endava has implemented this Policy for the purpose of ensuring the confidentiality, integrity, and availability of Endava owned information or in the custody of Endava, supporting compliance with applicable laws, regulations, and industry standards, and promoting a proactive, risk-based, and accountable approach to managing information security.

3 POLICY SCOPE

This Policy applies to all Endava employees, directors, contractors, and third parties who access, process, store, or transmit Endava information or client information processed by Endava on their behalf. It covers all information systems, networks, physical environments, and data types used to support Endava's business operations.

4 POLICIES

4.1 GUIDING PRINCIPLES

The following principles provide the overarching framework for the CyberSecurity (also known as "information security") practices of Endava:

- CyberSecurity is concerned with maintaining the confidentiality, integrity and availability of all Endava systems, networks, and information assets.
- All Endava personnel are required to obey the laws and regulations of the jurisdiction where they are working, as well as the jurisdictions where systems that they are working on reside.
- Information (in all of its forms) is a valuable corporate asset which must be protected from theft, unauthorized access, or loss.
- All information on Endava systems and networks is either the property of Endava itself or is being held by Endava for another organization (typically a customer).
- All Endava personnel are responsible for the protection of Endava and customer information and are expected to exercise attention, caution, prudence and taking reasonable steps in the handling of information and assets containing information such as computers, media and paper.
- The systems, networks and software provided by Endava are meant to be used for business purposes. Any non-Endava business usage must be minimal and in accordance with Endava policies. Endava personnel should ensure any such use remains appropriate and may consult their Line manager if clarification is required.
- Endava takes a risk-based approach to CyberSecurity, applying security controls and processes to information, systems and networks which are commensurate with their value.
- Endava personnel and systems must be given access only to information which is required for them to accomplish their assigned tasks (principle of “Least Access”).
- Before any access is granted to information which is not classified as PUBLIC, the identity of the user requesting the access must be ascertained and their authorization to access the data confirmed.
- All systems and networks implemented at Endava must be designed with security as a basic requirement, including multiple layers of defence which support each other.
- Information must be protected from threats to its physical security as well as from threats of an electronic nature.

All of the policies in this document, as well as any standards or procedures which have an impact on CyberSecurity must be in accord with the above principles.

4.2 SECURITY RESPONSIBILITIES AT ENDAVA

4.2.1 Responsibilities of all personnel

EVERY ENDAVAN IS RESPONSIBLE FOR EXERCISING ATTENTION, CAUTION, PRUDENCE AND TAKING REASONABLE STEPS IN THE PROTECTION OF INFORMATION AT ENDAVA. THIS MEANS FOLLOWING SECURITY POLICIES, STANDARDS, PROCEDURES AND INSTRUCTIONS FROM CYBERSECURITY AND EXERCISING SOUND JUDGEMENT IN THE COURSE OF THEIR DUTIES.

LINE/PEOPLE MANAGERS ARE RESPONSIBLE FOR ENSURING THAT PERSONNEL UNDER THEIR SUPERVISION UNDERSTAND AND COMPLY WITH SECURITY POLICIES AND PROCEDURES.

All Endava personnel are required to promptly report any potential security incidents, vulnerabilities or risks which they become aware of to ITS by opening a ticket in [SNEAP](#) or directly to cyber.soc@endava.com.

Senior and Executive Management are responsible for providing strategic direction and oversight for information security, ensuring alignment with business objectives, allocating appropriate resources, supporting a security-aware culture, and reviewing key risk indicators as part of their governance duties.

4.2.2 CyberSecurity Group

The CyberSecurity Group is a logical entity encompassing (i) Cyber Security Center of Excellence reporting to Head of Security Operations; (ii) CISO Office reporting to the Chief Information Security Officer (CISO), and (iii) Cyber Security Engineering Team (CSET).

Endava's CyberSecurity Group holds primary responsibility for:

- Developing an information and physical security strategy for Endava which addresses the risks and threats facing the organization.
- Implement new and appropriate security technologies to ensure that maintain high standards against new and evolving security threats.
- Maintaining situational awareness and documentation of internal and external risks and threats to the confidentiality, integrity and availability of Endava systems and information.
- Developing and recommending security policies for all organizations within the Endava group to the Controls and Policy Committee.
- Developing technical and operational standards and working with Enterprise Architecture to develop architectures for the implementation of security policies, including:

- Baseline configuration requirements for hardware and software.
- Security Non-Functional Requirements for hardware and software.
- Providing security subject matter expertise to Endava personnel, including assessment of proposed systems' compliance with the CyberSecurity Policy.
- Design and operation of security monitoring and response systems
- Design and performance of security testing and assessments of Endava systems, networks, applications and people.
- Design and operation of a Vendor Risk Management program for the evaluation and monitoring of information security risks related to third party service providers
- Development, testing and execution of incident response plans for and responding to security incidents.
- Development, testing and execution of business continuity plans for and responding to significant business disruptions.
- Performing periodic reviews and recommending necessary updates to security policies.
- Providing guidance to the company for compliance with applicable audit standards, industry best practices, and (in concert with Legal and Compliance), legal and regulatory requirements.
- Oversee information security performance measurement and continuous improvement metrics.
- Maintain records of all risk management decisions and periodic reviews for audit.

4.2.3 Security Risk Management Process

All projects and significant infrastructure or application changes undertaken at Endava must include the consideration of potential risks to the confidentiality, integrity and availability of systems, networks and information as well as mitigations for those risks. The CyberSecurity group must participate in this review of risks and mitigations and issue findings as to:

- Whether all risks to confidentiality, integrity and availability have been raised, considered and addressed
- Whether the project as described is in conformance with the CyberSecurity policy, as well as applicable laws, regulations and security related contractual undertakings to customers.

- Whether there are additional controls or mitigations which need to be added to the project in order to reduce risk.

The CyberSecurity group will ensure that if required a security risk assessment document will be produced, which will describe the relevant information security risks and mitigation steps that have been agreed to. This document will become part of the project requirements.

Should the scope or nature of a project change in a material way, it is the responsibility of the business owner to work with CyberSecurity to update the risk assessment.

If the CyberSecurity group establishes that the residual risk after all controls have been implemented, the business owner may seek Risk Acceptance.

The Risk assessment document will be prepared by CyberSecurity and will assess:

- The project to be undertaken
- The threat, likelihood and impact = risk
- Any applicable policies, legal, regulatory, or contractual commitments
- Any controls that will reduce the risk.
- Clearly document the residual risk once all reasonable controls have been implemented – the controls will be dip sampled.

This Risk Acceptance Document must be reviewed and approved by an appropriate authority dependant on the level of residual risk.

All Risk Acceptance Documents must be reviewed periodically by the Cyber Security group and the Business Owner to ensure that they are still applicable and appropriate.

4.2.4 Controls and Policy Committee

The Controls and Policy Committee (CPC) has overall responsibility for all corporate policies and must approve this policy on an annual basis. The CPC must also approve any changes made to this policy.

4.3 SECURITY TRAINING AND AWARENESS

Endava considers security awareness and training to be a core element of our overall information security program. The purpose of the [Security Training and Awareness Program](#) is to provide all Endavans with:

- Baseline security awareness training at the time of onboarding with an accompanying skills assessment
- Ongoing educational activities such as newsletters, signage, videos, phishing and social engineering testing, and training sessions to reinforce the basic security awareness messages

- Training and awareness materials for specific constituencies within Endava (such as software developers, finance personnel, HR personnel, etc.) tailored to their needs and the threats they face
- Annual security awareness refresher training with an accompanying skills assessment

All Endavans are required to complete the baseline information security training and pass the associated skills assessment during their onboarding process.

All Endavans are required to complete the security awareness refresher training and pass the associated skills assessment annually.

Training effectiveness must be measured. For example, through phishing simulations and tracked completion rates.

Endava personnel are required to attest to their understanding of and adherence to all security policies and directives issued by the company at onboarding and then on an annual basis.

From time to time, Endava may require some or all personnel to take additional security training and/or pass skills assessments.

Prior to their last day of work, any Endavan leaving the employment of the company must be advised by Human Resources of their ongoing security commitments to Endava as a result of employment agreements and attest to this awareness and compliance.

4.4 GENERAL COMPUTER AND NETWORK USAGE

Endava and client systems include any electronic device or network which is owned by Endava, its clients, or associated service providers. This includes “cloud based” systems which are operated by third parties on behalf of Endava or its clients.

The concept of “use of Endava systems” includes:

- Access to any Endava IT systems from any electronic device in any location
- Access to Internet based resources from Endava’s network
- Access to Endava premises
- Access to Endava information stored in any format

The concept of “use of client systems” includes:

- Access to any Endava customer’s IT systems from any electronic device in any location
- Access to Internet based resources from Endava’s network
- Access to Endava customer premises
- Access to Endava customer information stored in any format

Endava and client systems may only be used to conduct business between Endava and its clients, suppliers, and other business partners.

Endava and client systems and networks must not be used in any manner which:

- Violates the laws and regulations of jurisdictions where they are located
- Harasses persons inside or outside of Endava
- Interferes with the business operations of Endava, Endava clients, or third parties
- Infringes on copyright or other intellectual property rights
- Attempts unauthorized access to information
- Disables or interferes with any required security feature
- Introduces malicious or self-replicating code
- Is a business use for a non-Endava entity
- Attempts to circumvent or evaluate without authorization the security of Endava or any external entity
- Involves political activity or fundraising
- Damages Endava's reputation or brand or that of clients
- Violates any other Endava policies

4.5 END USER COMPUTING

"End user computing" refers to use of desktop or laptop computers, mobile devices, or cloud based services by Endava personnel in the course of performing their duties.

4.5.1 Asset Management

All end user computing assets must be recorded in the corporate asset management system operated by IT and must be physically labelled with a unique serial number.

End user computing assets must be assigned either to IT inventory or to a specific, named Endava user, who is responsible for exercising attention, caution, prudence and taking reasonable steps to protect the asset from damage, loss or theft. End user computing devices must only be used by the person they are assigned to.

4.5.2 Operating Systems

The following operating systems are approved for use on Endava owned end user computing devices (within two major versions of current operating system release):

- Microsoft Windows (desktops, laptops, mobile devices)
- Apple MacOS (desktops and laptops)
- Apple iOS/iPadOS (mobile devices)
- Android (mobile devices)

Installation of any other operating system on to an Endava owned asset must have both a business justification and approval from IT with risk assessment from CyberSecurity.

End user computing devices must be created from master images maintained by IT. These images must be reviewed and risk-assessed by CyberSecurity periodically.

Operating systems on end user computing devices must be kept updated with security patches and updates in a timely fashion. Use of versions of operating systems which are no longer supported or patched by their manufacturers is prohibited. Users must not tamper with the operating system settings and policies as installed by IT or CyberSecurity

4.5.3 Malware protection

All end user computing devices must be protected with:

- Anti-malware/Advanced Threat Prevention, Detection and Response solutions which are approved, monitored and managed internal tech and monitored by CSCoE.
- Web filtering technology which prevents access to known sources of malware.
- Perimeter malware and phishing detection and blocking on email accounts

Any anti-malware solutions which depend on signatures or updates must be set to automatically update themselves at least daily.

If a user has reason to believe that their end user computing device has been infected by malware, they must disconnect/isolate the device from all networks and inform Cyber.soc@endava.com immediately. Signs of potential malware infection include messages from anti-malware software and unexpected behaviour of the system.

Tampering with or disabling anti-malware protections is an especially serious violation of policy.

4.5.4 Credentials

End user access to Endava systems, networks and applications must require a user to authenticate their identity via a method approved by CyberSecurity. Wherever technically possible, this will be via:

- Endava user name and password (for connections within the Endava network)
- Endava user name, password and multi-factor authentication (for external connections and connections to approved cloud based applications) where technically possible

Users are responsible for all actions taken using their credentials.

User IDs, passwords and authentication devices must be assigned to one specific person and must not be shared or used to permit others to access Endava resources. Unauthorized use of another person's (or system) credentials is a serious policy violation.

Users must not use any password that they use on an Endava system on any other system inside or outside of Endava.

Passwords must be constructed and managed according to the instructions in the [Endava Password Standard](#). CyberSecurity is responsible for ensuring that the [Endava Password Standard](#) reflects current threats to password security and that passwords chosen by users are compliant and properly constructed.

Passwords must be stored securely – they must not be written down or stored in non encrypted electronic storage. CyberSecurity will provide users with guidance on acceptable password storage methods in the [Endava Password Standard](#).

Users must only utilize the Password Security Manager (Keeper) that has been risk assessed and meets Endava's risk appetite/management process and has been approved for use. **The use of browser password managers for saving and storing Endava and client credentials within web browsers is strictly prohibited.**

If a user has reason to believe that their credentials have been compromised, they must immediately change their password and inform CyberSecurity.

4.5.5 Installing hardware and software

Selection, purchase, configuration and maintenance of desktop and laptop computers connected to Endava networks is the responsibility of the Internal Technology function. Users must not connect any hardware to Endava networks without prior written permission from IT and CyberSecurity.

Users must not connect peripheral devices such as external storage, additional network adapters, TV tuners, etc. without a business justification and permission from IT and CyberSecurity.

Selection, purchase, configuration and maintenance of software on laptop and desktop computers connected to Endava networks is the responsibility of the Information Technology function (IT). Users must not install any software on Endava computers without prior written permission from IT and CyberSecurity. Software approved for end user installation is listed on Confluence within the [TEAM Tools Standard](#) document or available at the Company Portal application. Installation of any other software requires a business justification and approval from IT and appropriate risk management from Cyber Security.

All software installed on end user computing devices must be properly licensed to Endava for commercial use and must have a business justification approved by the user's Line Manager. Software license terms must be approved by Endava Legal before software is installed.

End user computer devices must not be used to run server software to which other users connect for services in a production environment.

4.5.6 Required security features

All end user computing devices must be configured with the following security features at all times:

- The device must require a user name and password to be entered on startup as well as when waking from sleep or hibernation states.
- The device must have an automatic screen locking feature which activates after 15 minutes of user inactivity. Unlocking the screen must require a user name and password. When leaving their device unattended, users must activate the screen lock feature.
- The device must be configured to automatically install software updates as directed by IT
- The system must be configured to log security events, which should be uploaded to a secure repository periodically.
- All non-essential services, especially those which accept network connections, must be disabled by default.
- The device must be protected from remote connections by a firewall solution.
- Laptops, phones, tablets and other devices designed for mobile use must be configured with full disk encryption.

Devices shall maintain such controls as defined in [Device Security Policy](#) in order to be able to access Corporate resources.

4.5.7 Wireless networks

Endava provided end user computing devices may connect to wireless networks in order to access the Endava network.

No end user computing device may be connected simultaneously to an Endava network and a non-Endava wired or wireless network (including peer to peer ad-hoc networks) simultaneously unless approved by IT and CyberSecurity. Connections over the public Internet to the Endava VPN are approved.

No end user computing device may be connected simultaneously to a wired or wireless network specified for “guest” or “bring your own device” use and an Endava network unless approved by IT and CyberSecurity.

Usage of “guest” or “bring your own device” networks is subject to acceptance of such networks terms & conditions.

4.5.8 Data storage and backup

Storage devices in end user computing devices are meant for temporary storage of information which is being worked on. These devices are not backed up. Users must ensure that any important data is copied to Endava network storage (including authorized cloud based storage) for long term storage and backup.

Non business related personal information must not be stored on an Endava device.

4.5.9 Use of cloud based services

Cloud based services are defined as services provided over the internet, rather than hosted on a local server or personal device. Such services can be used to store, process or transmit Endava or client information.

Use of cloud based services must be reviewed and appropriately risk managed by CyberSecurity prior to their use for Endava business.

Cloud based services used by Endava must operate under a shared responsibility model clearly documented by the business owner and provider. These cloud services must support encryption in transit and at rest, enforce multi-factor authentication (MFA), and must support federated identity with Endava's Active Directory environment unless an exception is granted by CyberSecurity.

Some clients may approve/require the use of cloud based services in connection with work performed by Endava. CyberSecurity must be made aware of these services and ensure that they do not pose a threat to Endava's or other customers' security.

Periodic reassessment of approved cloud services must be scheduled at least annually.

For more details, please refer to [Cloud Security Policy](#).

4.5.10 Remote working

When working remotely, users must exercise attention, caution, prudence and taking reasonable steps to protect Endava information and assets from loss, damage or theft. This includes, but is not limited to:

- Maintaining awareness and possession of devices containing Endava or client information
- Avoiding situations where unauthorized personnel can see or hear Endava or client confidential information
- Securely disposing of Endava and client information

Remote access to the Endava network must be via the approved VPN solution operated by IT and risk assessed by CyberSecurity. Endava endpoints are equipped with an always on VPN solution. Disabling or uninstalling such solution is considered policy offense unless an exception has been defined following approval from IT and appropriate risk assessment by CyberSecurity. Users must not access Endava resources using external VPN services or other services which obfuscate the origin of the connection.

Any Endava resource which is accessible from the Internet (approved cloud apps, or the VPN for example) must be configured to require multi-factor authentication before a user is permitted access.

4.5.11 Administrator access

All Endava systems must be configured to provide remote administrator access to authorized personnel in the IT and CyberSecurity groups. This access must only be used in support of Endava business, maintenance and support, or the investigation of a logged CyberSecurity event.

Endava may provide users with administrative rights to their workstations in order to facilitate the development of software and solutions. Provision of administrator access does not exempt users from any other security policies, in particular those around software installation and operating system configuration.

4.5.12 Prohibited content

Users must not store any content on end user computing devices which violates Endava policies or applicable laws and regulations. Examples include but are not limited to:

- Unlicensed or improperly licensed software
- Unlicensed or improperly licensed music, movies, or books
- Peer to peer file sharing software
- Destructive software (malware)
- Cryptocurrency mining software
- Hacking tools
- Inappropriate material as defined by policy, regulations and local laws.

4.5.13 Monitoring and privacy

Endava reserves the right to monitor all activity performed with and content stored on end user computing devices owned by the company. Such monitoring may be performed by the IT or CyberSecurity groups strictly for the purpose of maintain and ensuring the security of Endava and or client systems. Any monitoring to be carried out shall be proportionate to this purpose and must comply with applicable privacy regulations

Personal (non-work related) information and data/media such as photos, videos and music must not be stored on end user computing devices.

4.5.14 Use of end user computing resources

Endava provides end user computing devices for use in the completion of Endava work. While occasional personal use of such devices is permitted, such use must not interfere with Endava's business or violate other sections of this policy.

Users must not allow any unauthorized person to use devices assigned to them.

4.5.15 Return, reuse and disposal of equipment

When end user computing devices are taken out of service, they must be securely erased and reimaged with the latest IT operating system image before being assigned to another user. If the device is to be disposed of, all storage components of the device must be either erased or physically destroyed within 6 months from the last day of the employee.

The asset management system must be kept updated with the status of all end user computing equipment.

4.5.16 Use of non Endava equipment for Endava business

All work done for Endava clients must be performed using Endava or client owned and managed end user computing devices (not including mobile devices).

Users may access the approved Endava applications or the Endava "Guest" network (provided for Internet access only) using non Endava computers, but must not download Endava or client information to non-Endava systems. Non Endava computers used to connect in these cases must be:

- Configured to require a user name and password to access the system
- Configured with a host firewall to deny inbound connections
- Configured with screen locking after 15 minutes of inactivity
- Configured with encryption of data at rest

- Equipped with up to date anti-malware protection
- Kept updated with security patches for and be a currently supported version of the operating system, browsers and plugins.

Users may install approved Multi-factor Authentication applications on their personal mobile phones to assist in the protection of their Endava credentials.

Users who wish to access their Endava email, collaboration tools or data from a personally owned mobile device agree by default upon connection to the installation of mobile device management (MDM) or Mobile application Management (MAM) software on the device. This software will be used for following purposes only:

- Enforcement of screen locking
- Enforcement of device encryption
- Enforcement of anti-malware requirements
- Detection of “jailbroken” devices
- Removal of Endava information from the device should it be lost or stolen, or should the user leave Endava’s employment

Devices which have been “jailbroken” may not be used to access, store or transmit Endava information.

Devices which have been determined by CyberSecurity to be vulnerable to malware infection must be protected by an anti-malware solution.

Personal devices may only be connected to the Endava network via the “Employee Guest” wireless networks provided for this purpose. These networks must be completely segregated from Endava corporate networks and provide filtered Internet access only. External IP addresses for these networks must be distinct from other Internet connection points. Endava reserves the right to block any device showing signs of malware infection or other risk factors from the Guest network.

CyberSecurity reserves the right to prohibit the use of certain devices or classes of devices for use in conducting Endava business should it determine that these devices pose a security risk to the company.

4.6 SERVERS & INFRASTRUCTURE

“Servers” refer to computers which provide services to multiple users or which run background processes in support of network applications or infrastructure. Servers are generally accessed via network connections, not via their attached keyboard/mouse/screen except when being maintained by authorized service personnel. Servers may be located in Endava premises (offices or data centers) or hosted at cloud service providers.

“Infrastructure” refers to equipment used to provide network connectivity between Endava systems and networks and includes, but is not limited to, routers, switches, wireless access points, storage access networks, and the links connecting these components.

4.6.1 Control of infrastructure

The installation, modification, maintenance or deinstallation of any server or infrastructure equipment must be approved and performed by the IT function according to Endava’s [Change Management procedure](#). Employees are forbidden from connecting any hardware to the Endava network without prior written approval from the IT and CyberSecurity group.

4.6.2 Asset management

All servers and infrastructure devices must be registered in an asset management system which includes at a minimum the name, location, business purpose, business owner, technical owner, network location, physical location and hardware/software configuration of the devices. This asset management system must be kept up to date by Internal Tech.

4.6.3 Network connections and firewalls

All points of connection between Endava and non Endava networks as well as between networks of differing security domains must be protected by an approved firewall or other access control device. The default configuration for these connections must be to deny all connections except for those which are specifically allowed.

All changes to firewall and other access control devices must be documented, processed through the standard Change Management procedure and approved in advance by IT and CyberSecurity.

No hardware may be connected simultaneously to an Endava network and a non Endava wired or wireless network (including peer to peer ad hoc networks) simultaneously unless approved by IT and CyberSecurity.

No hardware may be connected simultaneously to a wired or wireless network specified for “guest” or “bring your own device” use and an Endava network unless approved by IT and CyberSecurity.

4.6.4 Wireless networks

All wireless networks on Endava premises must be designed, installed, maintained and monitored by IT. CyberSecurity must maintain a registry of approved wireless networks and periodically check Endava premises for unauthorized wireless networks.

Wireless networks which provide access to the Endava corporate network must be encrypted and require authentication by the user in order to join them. They must be subject to the same security controls as wired networks, including but not limited to web filtering, email filtering, intrusion detection/prevention, data loss prevention and anti-malware. Use of these networks is limited to Endava owned and managed devices.

Wireless networks which are provided for the convenience of guests or employees must also be encrypted. These networks may provide only Internet access and must not offer direct connectivity to the Endava network. It is permissible to access Endava via the Internet VPN from these networks.

4.6.5 Operating system configuration and updates

Servers and infrastructure devices must be configured with current, vendor or community supported operating systems approved by Internal Tech and CyberSecurity and must be kept updated with security patches.

Servers and infrastructure devices must be configured according to secure baseline configurations provided by CyberSecurity.

Where possible, servers should be built from standard images which are configured according to secure baseline configurations provided by CyberSecurity. These images must be stored in a secure repository and updated with security patches on a regular basis.

Servers and infrastructure devices must be configured to expose the minimum services required for their business application.

4.6.6 Accounts and passwords

Servers and infrastructure devices must have all default accounts disabled or the passwords for these accounts changed to passwords which are compliant with [Endava's Password Standard](#) before they are deployed.

All accounts, including service accounts, on servers and infrastructure devices must have a minimum of a user name and password compliant with [Endava's Password Standard](#).

4.6.7 Software installations and upgrades

Installation, modification, upgrades and deinstallation of software on servers and infrastructure devices must be carried out by authorized personnel according to [Endava's Change Management process](#).

All software installed on Endava systems or networks must be reviewed and approved by CyberSecurity prior to installation.

Software patches and updates which address security vulnerabilities must be installed in a timely fashion according to vendor and CyberSecurity recommendations.

4.6.8 Management, monitoring & logging

All servers and infrastructure devices must be monitored to ensure that confidentiality, integrity and availability objectives are met.

In order to facilitate investigations and provide accountability for management functions, CyberSecurity must have access to administrator level accounts on all servers and infrastructure. Use of this access must be limited to documented investigations and security monitoring.

Servers and infrastructure devices must be configured to log events which are required to investigate security incidents, including but not limited to authentication, authorization, configuration changes, and startup/shutdown. Depending on the nature of the device and the service offered, CyberSecurity may require additional logging to be configured.

Security log information must be stored in a format and location which prevents an attacker or system user from modifying or deleting log information.

Security log information must be retained for a minimum of 90 days. Depending on the nature of the system, CyberSecurity may require longer retention periods for certain systems or devices.

Management of servers and infrastructure devices must be done over encrypted channels such as SSH, or HTTPS using multi-factor authentication wherever technically possible.

4.6.9 Operational resiliency

When designing server and infrastructures for Endava or customer use, the need for operational resiliency must be taken into consideration.

Servers and infrastructure devices must be configured for the secure backup of data and system configuration information in a manner appropriate to the confidentiality, integrity and availability requirements of the supported applications.

Backup media and cloud backups must be encrypted using an algorithm and implementation approved by Endava CyberSecurity. Backup media must be stored in a secure and climate-controlled facility approved by CyberSecurity.

Servers and infrastructure supporting critical or time sensitive business functions must be designed with an operational resiliency plan which meets the Recovery Time Objective and Recovery Point Objective defined by the system's owner. These plans must be reviewed annually and tested for effectiveness, including failover simulation and backup restoration. Testing outcomes must be documented and retained for audit.

4.7 EMAIL AND ELECTRONIC COMMUNICATIONS

Endava personnel use a number of electronic communications platforms to interact with each other, with clients and with external business partners. These platforms include, but are not limited to, electronic mail ("email"), instant messaging ("IM" or "chat"), audio and video conferencing, and collaboration platforms. The following policies are applicable to all forms of electronic communications used by Endava personnel.

4.7.1 Appropriate use

Endava provides its personnel with access to electronic communications platforms to allow them to conduct company business.

Occasional personal use of Endava email accounts is permitted to the extent that it does not interfere with the company's business or work performance. However, there is no expectation of privacy of any personal emails sent via the Endava system.

Endava email addresses must not be used as account identifiers for any non Endava related external service.

Conversely, Endava business must be conducted over Endava approved communications platforms; personal or other non Endava email or messaging accounts are not to be used to conduct Endava business, except where such usage has been risk assessed and approved. Or use of a customer platform is required and approved.

The practice of forwarding Endava emails containing non public information to personal email accounts is specifically prohibited.

Endava communications infrastructure must not be used for any purpose which is:

- Illegal
- Intended to gain unauthorized access to any system or network
- Intended to harass another person or organization
- Intended to cause damage or interfere with the operation of a network or system
- Pornographic, racist, sexist, fraudulent, or offensive
- Misrepresentative of the identity of the sender
- In support of political fundraising, lobbying, or participating in political activities
- Endorsing any product or service, except with the approval of Endava senior management

- Likely to defame, embarrass, abuse, present a negative image of, or portray in false light, Endava, or any individual or organization.

4.7.2 Confidentiality

Endava communications platforms must be configured by default to protect the confidentiality of information while it is transiting non Endava infrastructure.

Endava personnel must follow all information classification and handling procedures as well as any customer limitations on data transmission, no matter the medium of communications. When sending information requiring encryption via electronic communications, approved encryption methods must be used to protect its confidentiality.

When creating or maintaining email distribution groups, or collaborative teams, care must be taken to limit membership to personnel authorized for access to the information processed.

4.7.3 Mobile access

Endava communications platforms may be accessed from mobile devices that are company owned and managed under the same conditions as desktop computer access.

In accordance with the [Device Security Policy](#), employee-owned mobile devices may also be used to access Endava communications platforms using approved apps, if the device is enrolled in Endava's Mobile Device Management (MDM) or Mobile Application Management (MAM) system and meets required compliance standards.

Endava classifies mobile devices into Compliant, Partially Compliant, or Non-Compliant tiers, which determine the level of access to Endava systems. Non-Compliant devices are blocked from connecting to Endava services, except for limited access to MyITS.

Mobile Device Management (MDM) and Mobile Application Management (MAM) software will be used by Endava for the following purposes ONLY on employee devices:

- Maintenance of an inventory of devices containing Endava data
- Enforcement of security features such as passcode locking, anti-malware software, and encryption
- Remote removal of Endava information should the phone be lost or stolen
- Remote removal of Endava information should the employee leave Endava

Use of jailbroken or rooted devices is strictly prohibited.

It is the responsibility of the user to promptly report the loss, theft or suspected compromise of any personally owned device containing Endava information. For guidance on reporting lost or stolen devices, see [4.17.5 Incident Reporting Guidelines](#).

Some customers may require additional security measures on non Endava devices or may prohibit the use of non Endava devices on their projects. These requirements will always supersede all other policies.

4.7.4 Privacy & monitoring

Endava has access to all information on its electronic communications platform and employees should be aware that Endava may and will access that information where required by law, to comply with any regulatory or other investigations or where necessary to comply with any contractual or other relevant obligation. Employees therefore should not use it for personally sensitive matters.

4.8 INFORMATION CLASSIFICATION, ACCESS, & HANDLING

Endava personnel handle information of varying types and sensitivities as part of their work at Endava. Some of this information is owned by Endava. Some is owned by our customers. In many cases, the unauthorized access to or modification/destruction of this information can cause significant damage to the revenues or reputation of or result in legal or regulatory penalties for Endava and/or its clients.

4.8.1 Owner & custodian

All information on Endava systems is either the property of Endava or its customers and may only be used for Endava or client business purposes.

All information at Endava must have a designated Information Owner, who is responsible for determining its classification and access rights. The information must also have a designated Custodian, who is responsible for ensuring that the information is protected in accordance with its classification as well as any specific client or owner requirements.

4.8.2 Classification levels

All information at Endava must have been classified to indicate its sensitivity as well as the instructions for its handling. Information must be classified as belonging to one of the following categories:

- **Strictly Confidential:** Information with access limited to a very specific group of Endava personnel, the unauthorized disclosure of which would have a very significant business impact
- **Confidential:** Information with access limited to a specific group of Endava personnel, the unauthorized disclosure of which would have a significant business impact

- Client Confidential: Information which is limited to Endava personnel working on a specific client
- Internal use only: Information which may be freely circulated within Endava, but which is not approved for disclosure outside of the company
- Public: Information which has been approved by Endava senior management for release to the general public.

More detailed information about and definitions of these classifications can be found in the [Endava Information Asset Classification Policy and Handling Guidelines](#) which presents a risk-based scale for determining the impact on the business of a loss of confidentiality, integrity, or availability for specific information.

Should a collection of information contain materials of varying levels of classification, the collection as a whole must be classified at the highest level of any component of the collection.

4.8.3 Employee access to information

Endava personnel must not disclose any non public Endava or customer information to any person or organization which is not specifically authorized to access it. When in doubt, employees must contact the Information Owner or CyberSecurity Group for guidance before providing access.

Employees must be granted access only to information which they need to perform their jobs and must not access or attempt to access Endava or client information that is not job related.

Any access to information classified as other than Public or Internal use only must be based either on a documented job profile or written approval from the Information Owner.

4.8.4 Privileged access

Some Endava personnel, including IT support and CyberSecurity staff, have privileged access to systems which contain information classified as Confidential, Client Confidential, or Strictly Confidential. This access is granted for the purpose of allowing the operation, maintenance and troubleshooting of systems as well as for the investigation of potential security incidents.

Such accesses must be provided where appropriate and technically feasible using “Just in Time” strategy.

All actions performed with such privileged access will be logged and reviewed regularly for anomalies.

Privileged access to systems is subject to quarterly review for appropriateness.

Personnel assigned of such privileged access must:

- Only use such rights for legitimate business purposes.
- Keep aforementioned information in strictest confidence
- Not use such information for personal benefit
- Not disclose such information to unauthorized parties

When providing operational support, privileged users must avoid accessing Confidential, Client Confidential, or Strictly Confidential information wherever possible.

Access to the content of employee communications by privileged users requires prior written approval by the Legal department, except in cases of immediate threat to security or safety.

4.8.5 External access

In cases where the Information Owner or client has approved the granting of access to non public information, the sharing method used must be conducted on an approved exchange application

External access must require authentication of all users; if the information being shared is classified as Internal Use Only, Client Confidential, Confidential or Strictly Confidential, any access via public networks must be protected with multi-factor authentication.

4.8.6 Client requirements

Endava clients may have specific requirements regarding access to the information they share with Endava. Should these requirements be more stringent than Endava requirements, they will supersede Endava requirements. Should they be less stringent than Endava requirements, Endava requirements will be used.

4.8.7 Access controls

Endava adopts a Zero Trust model for access management. All access requests must be explicitly verified, continuously validated, and granted based on the principle of least privilege.

Access to all information not meant for public distribution must be protected by physical and logical access controls proportional to its classification, as described in the [Endava Information Asset Classification Policy and Handling Guidelines](#).

In the case of electronically stored information, access controls must grant or deny access based on the identity (authentication) and access level (authorization) of the individual requesting access. Electronic access control systems must keep logs of the date, time, user identity, originating system, and result of the access request. Logs must be stored in a secure

manner, protected from unauthorized modification and retained according to Endava retention schedule.

Employee access to information must be reviewed and approved by the Information Owner at least annually as well as whenever there is a material change to the nature or use of that information to ensure that all personnel with access to non public information and privileged users still need that access.

When employees change job functions or leave Endava, their access rights must be adjusted or revoked accordingly.

4.9 ENCRYPTION

Endava requires the use of encryption to protect the confidentiality and integrity of information in certain circumstances, which are detailed in the [Endava Information Assets Classification Policy and Handling Guidelines](#) maintained by CyberSecurity.

All encryption tools, methods, and algorithms used to protect Endava or client information must be pre-approved by CyberSecurity. The following algorithm and key length combinations are approved for reversible encryption:

- **AES** – 256 bits recommended (128 bits minimum)
- **TDES/TDEA** – Triple-length keys
- **RSA** – 3072 bits or higher (2048 bits minimum for compatibility)
- **ECC** – 384 bits or higher recommended (224 bits minimum)
- **DSA/D-H** – 3072/256 bits or higher recommended (2048/224 bits minimum)

Home grown or non-recognized proprietary algorithms will not be approved.

All implementations of the above encryption algorithms must be made using industry standard encryption libraries approved by CyberSecurity. Encryption facilities built into Endava supported operating systems (Microsoft Windows, Apple MacOS) as well as the Linux Kernel Crypto API and OpenSSL libraries are approved for use without further consultation needed.

All connections to and from Endava systems which traverse the public Internet must be encrypted in transit.

Endava or client information stored on devices designed for mobile use such as laptops, phones or tablets must be encrypted at rest.

Encryption keys used for Endava purposes must be stored in a secure repository operated by CyberSecurity or its designate.

CyberSecurity is responsible for maintaining awareness of the ongoing security of algorithms, methods and tools used to protect Endava and client information and informing the organization of any emerging threats to confidentiality.

4.10 SECURE SOFTWARE DEVELOPMENT

When developing software for Endava or customer use, all Endava personnel must consider and address potential threats to the confidentiality, integrity and availability of the information being processed as well as of the underlying and connected systems and networks. Consideration of security is just one component of Endava's overall Software Development Life Cycle (SDLC), which provides overall governance and control of the software development process.

During project delivery, Endava may be subject to security policies and conditions which are specified by the customer. If these requirements differ from those set forth in this section, the customer requirements will apply. Project managers are responsible for ensuring that project personnel are aware of and comply with customer requirements. The requirements set forth in this section apply to delivery of internal projects as well as delivery of external projects for which the customer has not specified other policies or conditions.

4.10.1 Security and privacy by design

The design process for software must include consideration of the need for confidentiality, integrity, availability, and privacy of the information being processed. Security requirements must be established and documented for all software produced at Endava.

Wherever technically possible, authentication for systems used internally at Endava must be based on the corporate Active Directory infrastructure.

4.10.2 Development practices

When developing software, all Endava personnel must exercise attention, caution, prudence and taking reasonable steps and follow generally accepted practices to avoid introducing vulnerabilities. Developers must act in accordance with instructions provided by Endava managers and customer specifications regarding secure development processes.

4.10.3 Use of external software

The wide availability of open source and commercial software components and frameworks has increased the productivity of developers and the quality of software. However, it also presents new security challenges which must be addressed.

Endava personnel must make commercially reasonable efforts to select external software components which:

- Are current and supported at the time of selection
- Are free of significant security vulnerabilities at time of selection
- Have licensing terms which are compatible with Endava and customer requirements

4.10.4 Separation of environments

Separate environments must be provided for the Development, Test, and Production instances of software developed by Endava. Access to each environment must be limited using technical means to allow only authorized personnel to access the corresponding environment.

There must be a defined change management and deployment process which controls the promotion of code from development to test/QA to production environments. This process must limit the ability to deploy code to authorized personnel, keep a record of all deployment actions and provide a mechanism for detecting unauthorized deployments.

4.10.5 Testing and test data

When designing test plans for software, Endava personnel must:

- Consider threats to the Confidentiality, Integrity and Availability of systems and data.
- Take both use and abuse cases into account.
- Include tests for well known vulnerabilities associated with technologies used in the software.

Where technically feasible, synthetic data must be used for testing software functionality. If this is not possible, test data must be anonymized to remove personal information about actual persons.

If testing requires the use of non-anonymized personal identifiable information (PII), security measures equivalent to those used in production instances of the system must be applied to ensure the confidentiality and integrity of that information.

IMPORTANT: any use of PII as part of testing should be reviewed by the Group Data Protection Officer who will advise on legislative and regulatory compliance.

4.11 SECURITY TESTING & ASSESSMENT

Endava CyberSecurity Group is tasked with ensuring, measuring and assessing the protection of all of the company's networks, systems, software and people.

4.11.1 Responsibility for testing and assessment

Endava CyberSecurity Group is responsible for all security testing and assessment of Endava's systems, networks, software, premises, and users. No other person or entity may conduct security testing at Endava without written permission from CyberSecurity or the Board Audit Committee.

4.11.2 Technical testing and assessment

Endava CyberSecurity is responsible for performing technical testing of Endava systems, networks, software and people to measure performance against industry standards and best practices as well as corporate and customer requirements.

Endava must engage a qualified external security testing firm to perform an overall security assessment of the company at least annually.

Endava CyberSecurity must conduct automated vulnerability scans of all systems, networks and software at Endava at least monthly. Vulnerability scans of systems and networks which are exposed to the public Internet must be conducted at least weekly. Endava CyberSecurity is responsible for the triage and analysis of vulnerability scans, for informing system owners and operators promptly of the priority and nature of remediations, and for testing to ensure that security vulnerabilities are properly remediated.

All technical testing must be performed with attention, caution, prudence and taking reasonable steps to ensure that it does not interfere with the normal business operations of the company. Impacts on target and intervening networks and infrastructure must be considered and minimized.

IT must be informed of planned security or performance testing.

4.11.3 Testing of non Endava systems

Any security or performance testing of systems which are not owned and operated by Endava must be approved in writing by the system owner and the Chief Information Security Officer.

4.11.4 Personnel security testing

Endava CyberSecurity Group is responsible for conducting periodic tests which measure the effectiveness of its security awareness program and the level of awareness of and compliance with CyberSecurity policies.

4.11.5 Compliance testing and assessment

Endava CyberSecurity is responsible for ensuring the company's continued compliance with and certification under the following recognized international standards:

ISO/IEC 27001 – International Standard for Information Security Management Systems

ISO/IEC 22301 – International Standard for Business Continuity

Any other relevant standards for which we have a contractual requirement to follow.

Endava CyberSecurity is responsible for ensuring the company's continued compliance with the information security aspects of broader audits and assessments, including but not limited to:

IT General Controls
Sarbanes Oxley (SOX)
System and Organization Controls (SOC) 2 Type 2
Cybersecurity Essentials

4.11.6 Performance testing

Performance testing of Endava systems, networks or software may only be conducted with approval from IT, CyberSecurity, and the owners of the systems to be tested. When planning performance testing, attention, caution, prudence and taking reasonable steps must be observed to prevent interference with the normal operation of Endava systems and networks.

4.11.7 Test reporting

Endava CyberSecurity must promptly make the results of all security tests and assessments available to the:

Owners of systems, networks, software, processes being tested
Chief Information Security Officer
Chief Information Officer

All test and assessment reports are classified as "STRICTLY CONFIDENTIAL" and may not be shared with other persons or entities without the written approval of the Chief Information Security Officer.

4.12 SOFTWARE VULNERABILITY MANAGEMENT

Endava maintains a dedicated [Vulnerability Management Policy](#) that provides further detail and guidance for the activities described in this section.

4.12.1 Responsibility

Endava CyberSecurity has responsibility for monitoring industry sources, including but not limited to IT-ISAC advisories, vendor/maintainer advisories and reliable cybersecurity news sources for vulnerabilities which may impact Endava owned and operated systems. Should Endava employees, interns or contractors in other departments become aware of such vulnerabilities affecting systems which they are responsible for, they must contact

cyber.soc@endava.com for guidance and support in classifying and mitigating those vulnerabilities.

Vulnerability management and mitigation for systems which are owned by customers and operated on their behalf by Endava will be performed according to the relevant contracts, statements of work, and agreed upon customer procedures. However, Endava will aim to provide customers with notification of any applicable Critical/High priority vulnerabilities it becomes aware of.

4.12.2 Vulnerability scanning

All applications, services and tools that are owned, operated, and controlled by Endava and all other information system components, both internally and externally, that are under Endava administrative control or responsibility, and which interact with the first category system components should be included under vulnerability management scope.

All Endava owned systems must be scanned for vulnerabilities at least monthly.

4.12.3 Classification of vulnerabilities

All vulnerabilities will be classified into one of the following categories:

- Critical
- High
- Medium
- Low
- Information

The initial inputs into the vulnerability classification process will be:

- The Common Vulnerability Scoring System 3.1 (CVSS 3.1) score as published by the US NIST National Vulnerability Database.
- Information provided by Endava vulnerability scanning tools.
- Any additional rating information provided by the vendor or maintainer of affected software/components.

CVSS ratings will be classified into the following categories by default:

- Critical: CVSS score of 9 or above
- High: CVSS score of 7.0 - 8.9
- Medium: CVSS score of 4.0 - 6.9
- Low: CVSS score of 0.1 – 3.9
- Information: CVSS score lower than 4.0

Once an initial classification has been developed, Endava will determine whether there are any Endava specific mitigations or risks which would lead us to reclassify the vulnerability. Input into this reclassification process will come from CyberSecurity and ITS; the final decision as to classification rests with CyberSecurity.

Vulnerability classification may be increased by:

- Specific additional risks to Endava or its customers identified by the CyberSecurity team.
- Widespread ongoing exploitation of the vulnerability, especially if targeting similar organizations to Endava.
- Exposure of a vulnerable service/component to the global Internet.
- Customer requirements.
- Potential impact on external security ratings (ie BitSight, SecurityScorecard).

Vulnerability classification may be decreased by:

- Limits on access to the vulnerable service/component.
- Existing configurations of the vulnerable service/component which mitigate risk.
- Other mitigating factors which can be shown to reduce risk of exploitation.

If the categorization of a vulnerability is changed, documentation as to why it was changed must be kept.

Once a vulnerability has been classified, it will be the responsibility of Endava CyberSecurity to monitor vendor/maintainer and other industry sources for new information which may lead to further reclassification.

4.12.4 Vulnerability remediation plans

Vulnerability remediation plans must be developed and agreed to by CyberSecurity and ITS for any vulnerability which is classified as:

- Critical - within 3 days of discovery
- High - within 5 days of discovery
- Medium - within 30 days of discovery

Remediation plans must be risk based and take into account the need to balance business, operational and security requirements and must include plans for reversing changes if

necessary. If an operational or business requirement requires the acceptance of security risk beyond the risk appetite of Endava CyberSecurity, the system owner must be consulted and sign off a risk acceptance for approval by the CISO and CIO.

Remediation plans are to be documented in ServiceNow Change Requests.

4.12.5 Vulnerability remediation activities

The activities specified in vulnerability remediation plans must be completed within the following timeframes after the remediation plan is approved:

- Critical - 7 days
- High - 14 days
- Medium - 30
- Low – 60 days
- Information 90 days

4.12.6 Verification of remediation

Remediation activities for vulnerabilities classified as Critical or High must be verified by CyberSecurity prior to the Change Request being closed. Other vulnerability remediations must be verified during the next scheduled vulnerability scan.

4.13 END OF LIFE (UNSUPPORTED) SOFTWARE

It is Endava's policy to ensure that all systems under its control are running software which is supported by its developer and has not reached its End of Life. Software is considered to have reached End of Life when one or more of the following have occurred:

- The software vendor or open source project maintainer has stated that the software has transitioned to End of Life status.
- The software vendor or open source project maintainer has stated that they no longer plan to issue patches to security vulnerabilities found in the software.
- The software vendor has transitioned the software to "extended support" status, requiring payment of additional fees in order to receive security updates and Endava or its customer has elected not to enter into an extended support arrangement.
- The software vendor or open source project maintainer has ceased operations.

4.13.1 Avoidance of End of Life software

It is the responsibility of project teams to consider vendor software life cycles when choosing software components such as operating systems, tools and libraries and select those with the longest period of vendor/maintainer support remaining.

In cases where Endava is responsible for the ongoing operation of systems for its own use or the use of customers, operational teams are responsible for monitoring the support status of operating systems and other key software components and developing plans to move from End of Life to supported versions before the anticipated End of Life date.

4.13.2 Detection & classification of End of Life software

Endava CyberSecurity will include the detection of End of Life software in its routine vulnerability scanning of systems and will engage with system owners to remediate these cases. All systems running End of Life software must be placed into one of the following categories via discussions between CyberSecurity and the system owner:

- **Category A** - The server and installed software can run on a supported OS
- **Category B** - The server is no longer needed and can be decommissioned
- **Category C** - The server and/or installed software are NOT capable of running on a supported OS and the system is required to fulfil an Endava business function and there is no equivalent Endava standard solution available which would allow an upgrade or decommissioning
- **Category D** - The server is operated by Endava on behalf of a customer who has specifically instructed Endava in writing to continue operating the server using the end of life software and has accepted the accompanying risks

4.13.3 Remediation of End of Life software

In cases where End of Life software is detected on Endava's networks, remediation steps will be based on the categorization of the systems involved:

- **Category A** - Remediation plans for these systems must be developed and executed for within 60 days of their discovery.
- **Category B** - these systems must be decommissioned within 15 days of their discovery.
- **Category C/D** - systems in this category must be remediated within 60 days of discovery. Remediation means that the system must:

- Be isolated from other systems on Endava networks to the extent possible; they must be protected by firewalls/access lists which ONLY permit access to/from the specific systems which need to have access for the business functions of the servers to be achieved.
- Be isolated from the public Internet (no inbound or outbound access)
- Be reviewed every six months to determine if their status has changed, allowing them to be upgraded or decommissioned. (Category C reviews to be done internally, Category D reviews to be done jointly with the relevant customer)

4.14 WORKING ON CLIENT SITES & SYSTEMS

In some cases, Endava personnel will be required to use client supplied/managed IT systems and/or on client sites in the course of performing their duties. In these cases, Endava personnel are required to comply with all security policies and instructions provided to them by the client. If the client does not provide specific instruction on a matter of security, Endava policies must be followed. In all cases, the most restrictive or security-enhancing policy must take precedence, unless otherwise directed in writing by the client.

Endava personnel must use client systems which they have access to ONLY for the purpose of performing approved work for or at the instruction of the client.

In all cases, Endava personnel must exercise attention, caution, prudence and taking reasonable steps when using client systems and avoid actions which would place the confidentiality, integrity or availability of those systems or data at risk.

Any connections to client systems to/from Endava must be approved by CyberSecurity and IT and must be controlled using a firewall or other access control device.

4.15 THIRD PARTY VENDOR MANAGEMENT & ACCESS

4.15.1 Applicable third parties

This policy applies in cases where Endava plans to contract with an external entity which will store, process, transmit, or access Endava or client systems or information. These entities are defined as “applicable third parties.”

4.15.2 Contracts and agreements

Contracts and agreements with applicable third parties must:

- Not be signed until the applicable third party has been evaluated by CyberSecurity to determine whether the entity's security practices provide the proper level of protection for Endava and our clients.
- Include language committing the applicable third party to exercise attention, caution, prudence and taking reasonable steps in the protection of Endava and client information and to promptly inform Endava of any situation in which Endava or client information has been compromised.
- Include language committing the applicable third party to cooperate with Endava's [Vendor Risk Management procedure](#), including but not limited to providing relevant documentation, completing required questionnaires, answering security queries promptly, and for larger contracts, allowing on site audits to ensure continued compliance.

4.15.3 INFORMATION SECURITY ASSESSMENTS

CyberSecurity will assess applicable third parties against generally accepted industry standards for the protection of confidentiality, integrity and availability of systems and data, including but not limited to SSAE 18 SOC2 and ISO 27001 as well as against Endava and client security requirements.

Provider will be classified into one of the following risk tiers, with its corresponding reassessment periods:

Low Risk Tier (review every 18 months)

Medium Risk Tier (review every 12 months)

High Risk Tier (review every 6 months)

Very High Risk Tier (N/A, as Very high risk will be considered as Negative Assessment).

At the conclusion of its review, CyberSecurity will provide a response to the Business Owner for the project, which may be:

- Positive
- Positive with conditions
- Negative assessment

Any third party that scores above Endava risk appetite will require additional layers of risk management and controls, where this does not achieve risk appetite, appropriate risk acceptance will be sought with an appropriate authority dependant on the level of residual risk.

CyberSecurity responses are applicable to the specific services being contracted for at the time of the evaluation. Should the scope of services to be provided to the applicable third party change, the Business Owner must notify CyberSecurity of the proposed change before committing to the new services. The new services may require additional evaluation, conditions and mitigations at the option of CyberSecurity.

CyberSecurity responses will also specify the schedule and scope of periodic reviews of the applicable third party.

Third party will be also included in a continuous monitoring platform, if there is any event that calls for attention, Third Party will be required to provide additional information or mitigation information regarding such event.

If conditions are placed on the use of an applicable third party, the Business Owner is responsible for ensuring that these conditions are complied with for the life of the engagement.

If an approval includes a mitigation plan (actions that the vendor must take to mitigate risks identified by CyberSecurity), it is the responsibility of the Business Owner to ensure that the vendor fulfils its commitments related to mitigation. Should the vendor fail to fulfil these commitments, the Business Owner must immediately seek a new vendor for the services provided.

In the event that a vendor receives a negative assessment, CyberSecurity will provide the Business Owner with a written description of the risks that using the vendor would pose to Endava. Should the Business Owner still want to contract with the vendor, they will have to complete a risk acceptance process and get the approval of the Controls and Policy Committee.

4.15.4 Periodic reassessments

All vendors which store, process, transmit or access Endava or client information will be classified by CyberSecurity as to their criticality and will be subject to scheduled reviews to ensure that they are in continued compliance with agreed security practices and commitments.

4.16 PROTECTION OF PERSONAL DATA

Endava is committed to the protection of the confidentiality, integrity and availability of personal data stored on its systems or under its stewardship as well to compliance with all applicable laws and regulations related to that personal data. This policy provides baseline standards for the protection of personal data as well as additional requirements may be imposed by applicable laws and regulations.

IMPORTANT: any use of PII as controller or processor should be reviewed by the Group Data Protection Officer who will advise on legislative and regulatory compliance.

4.16.1 Collecting personal data

Endava will only collect personal data based on a documented business need or client requirement. Care must be taken to ensure that the collection of personal data is relevant to a business need and not excessive.

Personal data may only be used for the purpose(s) for which it was originally collected and must be accurate and as up to date as is reasonably needed for its purpose.

4.16.2 Definition of personal data

Endava defines personal data in accordance with the European Union's General Data Protection Regulation as "any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier such as a name, an identification number, location data, an online identifier or to one or more factors specific to the physical, physiological, genetic, mental, economic, cultural or social identity of that natural person."

Some jurisdictions in which Endava or its clients operate and/or some Endava clients may have a broader definition of "personal data." In these cases, to the extent applicable for the delivery of services or to comply with local law, Endava will adopt the broader definition for personal data held in that jurisdiction or for that client. Should this be the case, the definition of personal data must be included in the Master Services Agreement for the customer.

4.16.3 Storage and transmission of personal data

Personal data must be stored and transmitted in accordance with the [Endava Information Asset Classification Policy and Handling Guidelines](#).

Personal data must be adequately protected against unauthorized access, modification or destruction.

Personal data must not be transferred from one system to another without the permission of the data owner.

4.16.4 Access to personal data

Employees must treat all personal data which they have authorized access to in the course of their duties as confidential and use attention, caution, prudence and taking reasonable steps to protect that information from unauthorized disclosure. Endava personnel must not access or attempt to access personal data on any system unless they have been granted authorized access rights by the system or data owner.

Endava employees may have access to personal data on client systems in the course of providing services to clients. Endava employees must comply with client rules and procedures for access, usage and handling of such personal data, as well as all applicable laws and regulations.

4.16.5 Retention and destruction of personal data

Endava will retain personal data only for as long as is required for the purpose for which it was collected including any business needs and in accordance with the Endava Records Retention Policy and any applicable laws and regulations. When personal data is no longer needed, it must be securely destroyed.

It may not be possible to destroy all copies of personal data, for example, copies stored on backup media. For this reason, any backup media must be treated and secured as if it contains personal data.

4.16.6 Individual rights

Endava shall process personal data in a manner that respects individuals' rights under applicable data protection laws.

4.16.7 Third parties

When sharing personal data with third parties, Endava must only do so in accordance with applicable law and include language in contracts and agreements which commits the third party to:

- Take appropriate actions to have in place technical and organizational measures to safeguard the personal data
- Use the personal data in accordance with the terms of the contract
- Abide by all applicable laws and regulations as well as any specific customer or Endava security requirements for handling of personal data
- Promptly inform Endava of any known or suspected unauthorized access or breach of confidentiality, integrity or availability of personal data entrusted to it
- Destroy all copies of the personal data, to the extent allowed by law, at the conclusion of the contracted services.

4.17 CYBERSECURITY INCIDENT RESPONSE

4.17.1 Incident Response Planning

Endava must develop and maintain incident response plans to respond to CyberSecurity incidents, including but not limited to data breaches, malware infections, denial of service attacks, and system intrusions.

CyberSecurity is responsible for developing and maintaining documented incident response plans which provide guidance on the actions to be taken to detect, respond, contain, remediate and recover from CyberSecurity incidents.

Incident response plans must be reviewed at least annually to ensure that they are current and complete.

Security events are classified based on severity (Critical, High, Moderate, Low) in accordance with the Security Incident Management Process, which defines response expectations, impact levels, and escalation paths.

Legal privilege may apply to certain incidents. Guidance from the Legal team must be sought in cases involving data breaches, regulatory notification, or legal exposure.

4.17.2 Incident Response Plan Updates

CyberSecurity is responsible for monitoring threats to Endava which may require modification of incident response plans and updating the plans to include those threats.

4.17.3 Incident Response Plan Testing

Endava must conduct a test of its CyberSecurity Incident Response Plan at least annually and report the results to Endava management and the Board of Directors. Deficiencies found during these tests must be documented and remediated in a timely fashion.

4.17.4 External Incident Response Assistance

In some cases, Endava may elect to engage external assistance in responding to a cybersecurity incident. Such cases may include (but are not limited to):

- Incidents which involve unauthorized disclosure, modification or destruction of personal information which is reportable under applicable laws and regulations

- Incidents which involve the unauthorized disclosure, modification, or destruction of information entrusted to Endava by customers or other third parties
- Incidents which have resulted in Endava being in violation of contracts with customers or other third parties
- Other incidents which the Legal department has determined to pose a significant risk of litigation

The decision to engage external parties to assist Endava in its response to cybersecurity incidents shall be made by Endava's Legal Department, which is also responsible for the engagement of suitable experts and payment of professional fees and expenses in connection with these engagements.

All documents created by external parties engaged to assist in incident response shall be treated as legally privileged and confidential and shall be controlled by the Endava Legal department with distribution limited to:

- Endava Legal staff
- The Chief Information Security Officer
- The Chief Information Officer
- The Executive Leadership Team
- Endava's Board of Directors

Distribution of documents created by external parties in the course of cybersecurity investigations to any other persons or entities must be approved in writing by Endava's General Counsel prior to such distribution.

4.17.5 Incident Reporting Guidelines

All Endava personnel are required to promptly report any actual, suspected, or potential security incidents, weaknesses, or threats affecting Endava information, systems, or client data. These include, but are not limited to, data breaches, malware infections, unauthorized access, suspicious activity, or loss of devices containing covered information.

Reports should be made immediately, through one of the following channels:

- On the Portal: sneap.service-now.com/myits – “Fix Something”.
- By Email: “ITS” or “247support” (Endava internal Email only) or ITS@endava.com or 247support@endava.com (from outside Endava).
- The CyberSecurity Center of Excellence team: cyber.soc@endava.com may also be contacted.

For more detailed procedures including roles, responsibilities, and response timelines, refer to the [ISMS-END-Security Incident Management Process](#).

4.18 PHYSICAL SECURITY

Physical security is an integral part of Endava's overall CyberSecurity strategy; information, systems and networks need to be protected from physical as well as electronic risks.

4.18.1 Endava premises

Endava offices must be designed in a manner which provides a secure perimeter, controlling and recording access. In many cases this means use of access control systems using access cards and video surveillance (which may be managed by the building management company). All security systems and devices installed on Endava premises must be configured in accordance with local building codes, life safety regulations and best practices.

Access to Endava premises (offices, datacentres, etc.) is restricted to authorised persons, defined as employees, contractors, and invited visitors.

Some areas of Endava premises are designated as "limited access." Access to these areas must be limited to personnel whose job functions require such access. Facility Managers must have access to all portions of the Endava premises they are responsible for. Should employee job functions change, their physical access rights must be adjusted promptly. Access lists for limited access areas must be periodically reviewed.

Some Endava premises may be equipped with intrusion alarm systems as specified by Security. Each site must have a written procedure for the use of intrusion alarms, as well as for the periodic changing of arm/disarm codes.

Each Endava office must have a site Physical Security Plan which includes documentation of requirements, rules and procedures specific to the location. This document must be reviewed and approved by Endava CyberSecurity at least annually.

Endava data centers (premises dedicated to hosting electronic equipment only) must provide security and environmental controls to protect the hardware and information stored within. Controls must include access control and monitoring, fire detection and suppression, redundant power and cooling, and redundant communications circuits. Data centers are limited access areas; access to these areas must be approved by CyberSecurity and IT.

4.18.2 Access devices

Endava personnel may be assigned access devices such as access cards or keys. These must be safeguarded with attention, caution, prudence and taking reasonable steps and must not be shared with or loaned to other persons. Personnel must report the loss or theft of an access device to CyberSecurity as soon as possible.

In the event that Endava personnel are no longer employed by the company, their access devices must be collected from them during the exit process and where possible, electronically deactivated.

Building management staff may be provided with access devices which grant entry to all areas of the office. This access is to be used only for building maintenance, cleaning and for access in case of an emergency. Use of these access devices must be tracked and the devices tested on a monthly basis.

4.18.3 Securing information

Endava and client non public information must be physically protected from loss, destruction, theft, and unauthorized access or modification. Information may exist in various forms, including but not limited to paper, or electronic media.

The level and method of protection required for a particular piece of information depends on its classification. If a collection of information contains elements with different classifications, it must be handled according to the highest classification of information it contains. Specific instructions as to security requirements for classes of Endava information are contained in the [Endava Information Asset Classification Policy and Handling Guidelines](#).

4.18.4 Clean desk and clean screen policy

When not in use, non public information must be stored in a protected container as specified in the [Endava Information Asset Classification Policy and Handling Guidelines](#). Information must not be left unattended on desks, in printers or scanners, or in shared spaces such as conference/meeting rooms.

A clean screen policy must be observed at all times to prevent unauthorized access, requiring users to lock devices when unattended, enable automatic screen locks, avoid displaying sensitive data in shared areas, and ensure only authorized individuals can view screen content.

4.18.5 Securing IT assets

Endava personnel must exercise attention, caution, prudence and taking reasonable steps to ensure the physical security of IT assets assigned to their use, particularly when these devices are taken outside of Endava premises. Personnel must be able to account for the location of laptops, mobile phones, tablets and other equipment they are responsible for. This includes storing the equipment securely when traveling and reporting the loss or theft of any IT asset to CyberSecurity immediately.

4.18.6 Disposal of information

Endava information must be retained in accordance with applicable laws, regulations, legal hold requirements and corporate policies. If there is any doubt as to whether a piece of information should be disposed of, it should be stored securely and CyberSecurity contacted before it is disposed of.

Paper copies of non public Endava or customer information must be shredded using a cross cut shredder or placed in a secure shredding bin provided for that purpose.

Sites may choose to utilize external document destruction services. If an external document destruction service is utilized, it must provide Endava with a Destruction/Recycling report verifying the secure disposal of materials.

Electronic media containing non public Endava or customer information must be rendered unreadable via physical destruction or via a secure erasure process approved by CyberSecurity. Destruction must be logged and certified.

Failing electronic media (e.g.: failing hard disks) shall be stored safely until destroyed using a certified secure destruction service.

4.18.7 Visitors

Visitors to Endava premises must be sponsored by an Endava employee and must be on Endava business. The date, time, and purpose of each visit must be recorded in a visitor log. All visitors must be issued with a visitor badge, which they must wear in a visible manner. Visitors must be escorted by an Endava employee at all times while on the premises. Upon leaving Endava, the sponsoring employee must retrieve and return visitor credentials.

Use of Endava premises for meetings of outside groups must be approved by local facility management and security.

4.18.8 Filming, recording and photography

Filming, recording or photography in certain portions of Endava premises is prohibited; these areas must be equipped with signage at the entrance advising of this policy. Any exception to this policy must be approved in advance, in writing by CyberSecurity. In areas where these limitations are a customer requirement, customer permission must also be obtained in advance in writing from the client.

Recording of any telephone calls or online meetings must be conducted according to applicable laws and regulations. Meetings must not be recorded without the knowledge and permission of all attendees; any recording must include a statement advising participants of the fact that they are being recorded.

Endava may equip offices with video security systems. Recordings captured by these systems are considered personal information and must be properly secured with access limited to authorized personnel. Endava must comply with local laws and regulations regarding signage and notification in connection with video surveillance.

4.18.9 Offsite storage of documents and media

Critical paper documents and media (including back up tapes) must be stored in a secure offsite location with limited access, fire protection, and security controls approved by CyberSecurity. All critical paper documents should also be imaged and stored separately online. Media containing non public information stored offsite must be encrypted using methods and algorithms in accordance with this policy.

4.18.10 Reporting physical security incidents

Any physical security incident, including but not limited to the loss or theft of hardware, information or other assets, suspected intrusion into Endava premises by unauthorized personnel, or damage from a man-made or natural disaster must be promptly reported by the person discovering the incident according to [4.17.5 Incident Reporting Guidelines](#).

4.19 TRAVEL SECURITY

Each Endava employee should be familiar with this Policy and with Endava corporate policies applicable to business travel, including [Group Business Travel and Personal Expenses Policy](#).

Prior to travel, each Endava employee must conduct an independent risk assessment of the travel destination(s) considering information security risks. In this regard, [Stay secure while traveling](#) page should be consulted for advice.

Any issues, unusual device behaviour, or any other information security events occurred during the trip (such as lost or theft of devices, loss of physical documents and copies, etc.) must be reported as security incidents by traveller at the earliest opportunity, according to clause [4.18.10](#).

4.20 OMISSIONS & EXCEPTIONS

Should an information situation arise which has not been accounted for in this policy, Endava personnel must contact CyberSecurity for guidance. CyberSecurity will issue a Security Bulletin detailing the situation and instructions for dealing with it. This Security Bulletin will be sent to the Controls and Policy Committee for consideration of inclusion in the next revision of

this policy. Security Bulletins are considered temporary policies and must be published to the Endava community.

In a case where an Endava employee believes that business circumstances require an exception to be made, allowing an action contrary to this policy, they must make a request to Information Security in writing before taking action. CyberSecurity will conduct a risk analysis of the exception, consult with applicable stakeholders such as Legal, Compliance or Human Resources, and make a recommendation to the Controls and Policy Committee as to whether an exception should be granted, and if so, under what conditions. Final approval or denial for exceptions will be at the discretion of the Controls and Policy Committee.

All exceptions granted must be documented.

When an exception is granted, it is applicable only to the specific request made. For example, if project A requests an exception to policy and is granted the exception, project B cannot use that exception without a separate risk analysis and approval.

5 GOVERNANCE & OVERSIGHT

CyberSecurity is responsible for reviewing and updating this Policy annually, recommending final approval of the Policy - including significant revisions - to the Controls and Policy Committee, followed by the Endava Board.

6 BREACH OF POLICY

We are committed to upholding our company values in all aspects of our work. Therefore, failure to comply with this Policy may result in disciplinary action, leading up to and including, termination of employment.

7 AMENDMENTS

This policy sets out Endava's general approach to the matters it covers and is non-contractual, which Endava may, at its discretion, vary or amend from time to time.

8 POLICY REVISION

Revision	Date of revision	Description of update	Approved By
0.1	11.06.2020	New draft version for CPC approval	NA
1.0	17.06.2020	Initial version approved by CPC at meeting of this date	Controls & Policy Committee
2.0	01.10.2021	Clarifications and updates to sections 4.5.16, 4.12, 4.13 and 4.17	Controls & Policy Committee
3.0	16.06.2022	Review performed to align with Legal Team	Controls & Policy Committee
4.0	22.06.2023	Updates to sections 4.2.2; 4.5.2; 4.5.4; 4.6.6; 4.8.2; 4.8.7; 4.9; 4.16.3; 4.18.3; 4.18.4	Controls & Policy Committee
5.0	19.06.2024	Updates to sections 1; 4.2.1; 4.5.4; 4.5.5; 4.5.6; 4.5.9; 4.5.15; 4.5.16; 4.11.5; 4.12 Added section 4.19 Travel security	Controls & Policy Committee
6.0	16.06.2025	Updates to sections 1; 2; 3; 4.1; 4.2.1; 4.2.2; 4.2.3; 4.3; 4.4; 4.5.1; 4.5.2; 4.5.3; 4.5.4; 4.5.5; 4.5.6; 4.5.7; 4.5.8; 4.5.9; 4.5.10; 4.5.12; 4.5.13; 4.5.14; 4.5.16; 4.6.2; 4.6.5; 4.6.9; 4.7.1; 4.7.3; 4.8.2; 4.8.4; 4.8.5; 4.8.7; 4.9; 4.10.2; 4.10.5; 4.11.2; 4.11.6; 4.12; 4.14; 4.15.2; 4.15.3; 4.16; 4.16.4; 4.17.1; 4.17.5; 4.18.2; 4.18.4; 4.18.5; 4.18.6; 4.18.10.	Controls & Policy Committee